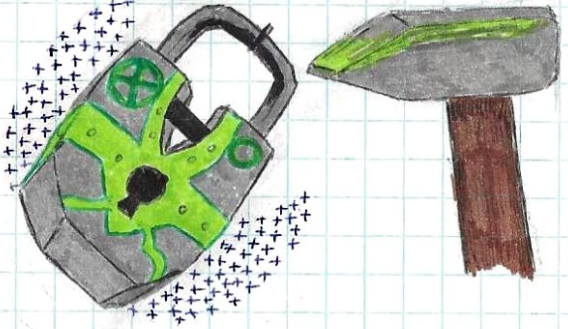


Password Attacks

Cathégorie : ⚔ Offensif
Difficulté : Medium, Tier I
Durée Estimée : 8 Heures

Introduction :

- Le module se concentre sur l'attaque et le contournement du principe d'authentification en compromettant les mots de passe des utilisateurs sur diverses systèmes d'exploitations, applications et methodes de chiffrement.

L'Authentification: est la validation de notre identité en présentant une combinaison de 4 facteurs à un mécanisme de validation. Ils sont:

[1] Quelque chose que vous savez (something you know) ; un mot de passe, un code d'accès, un code PIN, une phrase de passe, etc

[2] Quelque chose que vous avez (something you have), une carte d'identité, une carte à puce, un numéro de téléphone ...

[3] Quelque chose que vous êtes (something you are), caractéristiques biométrique, voix, reconnaissance facial, empreinte digital, retine...

[4] Un endroit ou vous êtes (somewhere you are), géolocalisation, adresse IP, etc

Le processus de validation peu exiger n'importe lequel de ces facteurs ou même les quatres en fonction de la criticité des informations à protéger
Notons qu'il y a toujours l'équilibre entre commodité (UX - Experience Utilisateur) et sécurité.

Introduction au Cassage de Mot de Passe :

Les mots de passe sont généralement haché lors de leur stockage afin de fournir une protection au cas ou ils tomberaient entre les mains d'un attaquant. Le hashage est une fonction mathématique qui transforme une entrée arbitraire d'octets en une sortie généralement fixe. Example de fonctions de hashage (MD5, SHA256, SHA1...). Les fonctions ont un sens unique on ne peux pas inverser le processus pour retrouver le mot de passe initiale. Mais il y a certaine techniques, Voyons d'abord comment hacher un mot de passe avec sha256.

```
Sécurisson@parrot ~$ echo -n "SuperPassword123!" | sha256sum
```

Tables Arc-En-Ciel : Sont des grandes tables de correspondance pré-compilé pour des valeurs d'entrée et de sorties pour des fonctions de hashage donné (Ex Online (Crack Station). Elles sont utilisé pour identifier très rapidement le mot de passe si son hashage correspondant à déja été mappé. Les rainbow tables sont si puissante qu'on utilise le salage →

Salage : Un sel en cryptographie est une séquence d'octets aléatoires ajoutés à un mot de passe avant qu'il ne soit haché. Pour maximiser l'impact les sels ne sont pas réutilisés deux fois empêchant ainsi une unique modification de toute la rainbow tables pour une base de donnée entière.

Attaque Brute-Force : L'attaque par force-brute sur le hash consiste a essayer toute les combinaisons possibles lettres par lettre chiffre par chiffre et symbole par symbole jusqu'a trouver la bonne combinaison. Cette methode met plus ou moins longtemps selon la fonction de hashage utilisée mais aussi la longeur du mot de pass. (< 9 caractère) le brute force reste raisonnable. Cela dis cette technique n'est presque jamais utilisé et bien souvent remplacée par l'attaque par masque bien plus efficace que nous détaillerons après.